

Projet Fabricool Active Directory Lab

Module 5 - PKI Microsoft et Services Web Sécurisés

TP11 — Déploiement de l'infrastructure PKI hiérarchique



Auteur : ODJEKE N'bango Thiery

Filière : Licence Professionnelle Réseau Cybersécurité

Date : 08/07/2026

Table des matières

I.	Objectif du TP.....	2
II.	Contexte	2
III.	Architecture	3
IV.	Travaux réalisés.....	3
1.	Préparation du Point de Distribution (IIS sur DC-S-01).....	3
2.	Déploiement de la Root CA hors-domaine (ROOT).....	7
3.	Déploiement de l'Enterprise Subordinate CA (DC-S-01).....	10
4.	Signature de la CSR par la Root CA.....	11
5.	Finalisation et configuration des extensions sur DC-S-01	14
6.	Publication et Validation Finale	17
V.	Conclusion.....	19

I. Objectif du TP

L'objectif de ce travail pratique est de mettre en place une infrastructure de gestion de clés hiérarchique (PKI) conforme aux standards de sécurité et aux bonnes pratiques de déploiement en environnement Active Directory.

Cette infrastructure doit permettre :

- * de garantir la protection des communications internes de l'entreprise,
- * d'assurer la délivrance et la gestion centralisée des certificats pour les différents services et équipements,
- * de renforcer la confiance entre les machines du domaine et les systèmes externes,
- * et de préparer le socle technique nécessaire à l'intégration future de services sécurisés.

La démarche consiste à déployer une autorité racine hors domaine, une autorité intermédiaire intégrée à Active Directory, ainsi qu'un point de distribution HTTP centralisé pour la publication des certificats et des listes de révocation.

II. Contexte

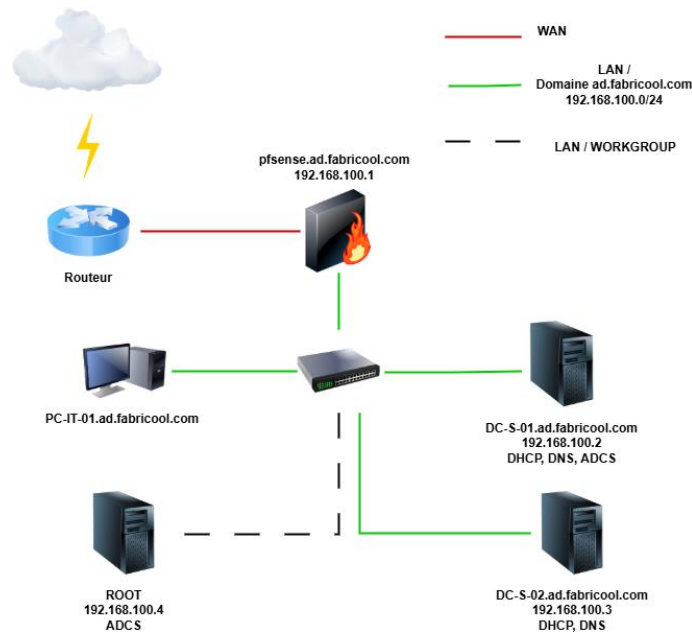
L'entreprise FABRICOOL souhaite renforcer la sécurité de son infrastructure informatique en adoptant une architecture PKI hiérarchique. Cette décision s'inscrit dans une logique de conformité aux bonnes pratiques de cybersécurité et de fiabilité opérationnelle.

La mise en place d'une autorité racine isolée du domaine permet de protéger la clé privée principale contre toute compromission. En parallèle, une autorité *intermédiaire* (SubCA) intégrée à Active Directory assure la délivrance automatisée des certificats pour les postes clients et les serveurs du domaine.

Afin de simplifier la distribution des certificats et des CRL, un serveur IIS dédié est utilisé comme point de publication central. Ce mécanisme garantit que tous les systèmes, qu'ils soient Windows, Linux ou macOS, puissent accéder aux informations nécessaires pour valider la chaîne de certification.

Cette infrastructure constitue un socle de confiance indispensable pour sécuriser les services internes de l'entreprise, tels que l'authentification, le chiffrement des communications et la protection des échanges web.

III. Architecture



Le schéma présenté inclut un parefeu pfSense pour illustrer une architecture réseau complète. Toutefois, ce TP peut être réalisé sans pfSense.

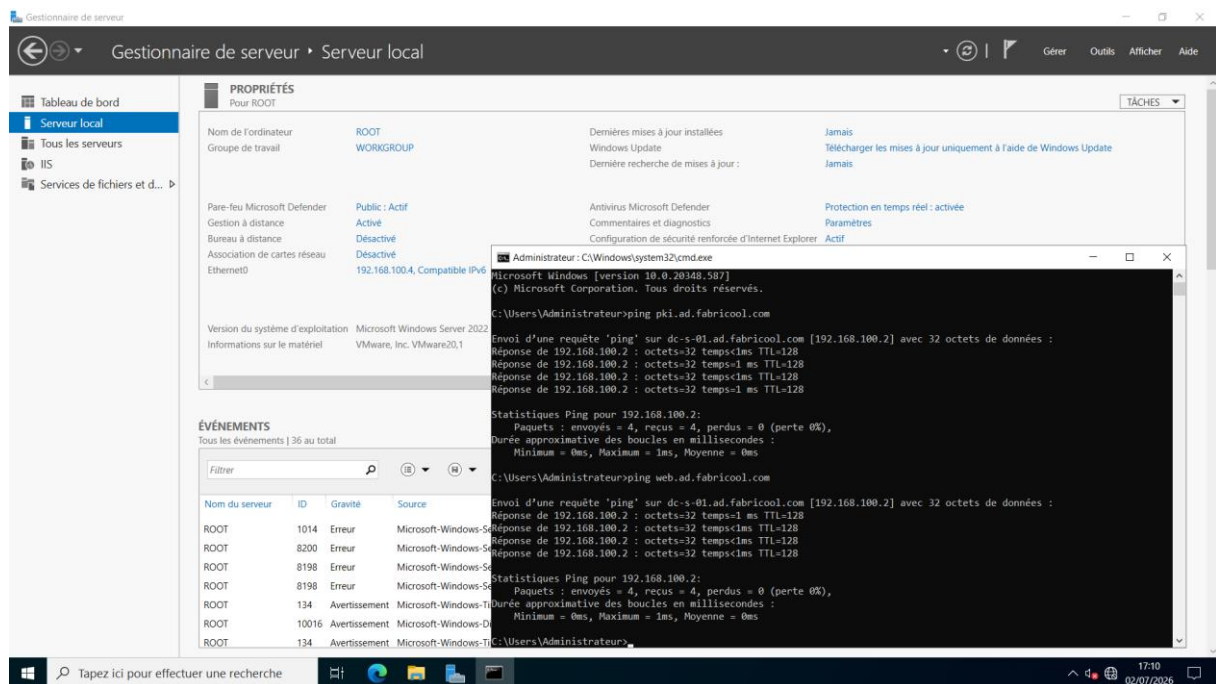
IV. Travaux réalisés

1. Préparation du Point de Distribution (IIS sur DC-S-01)

Avant l'installation des autorités de certification, il a été nécessaire de préparer le serveur Web afin qu'il puisse accueillir et distribuer les fichiers de liste de révocation (.crl) et de certificat (.crt). Cette étape constitue le socle de la mécanique de confiance, car elle garantit que tous les clients du domaine pourront accéder aux informations de certification via un point centralisé. Un premier contrôle a consisté à vérifier le fonctionnement des alias DNS associés au serveur DC-S-01 :

- * ***pki.ad.fabricool.com***, destiné au téléchargement des certificats et des CRL.
- * ***web.ad.fabricool.com***, réservé au futur site IIS sécurisé.

Un simple test de connectivité par ping a permis de confirmer la résolution correcte de ces alias.

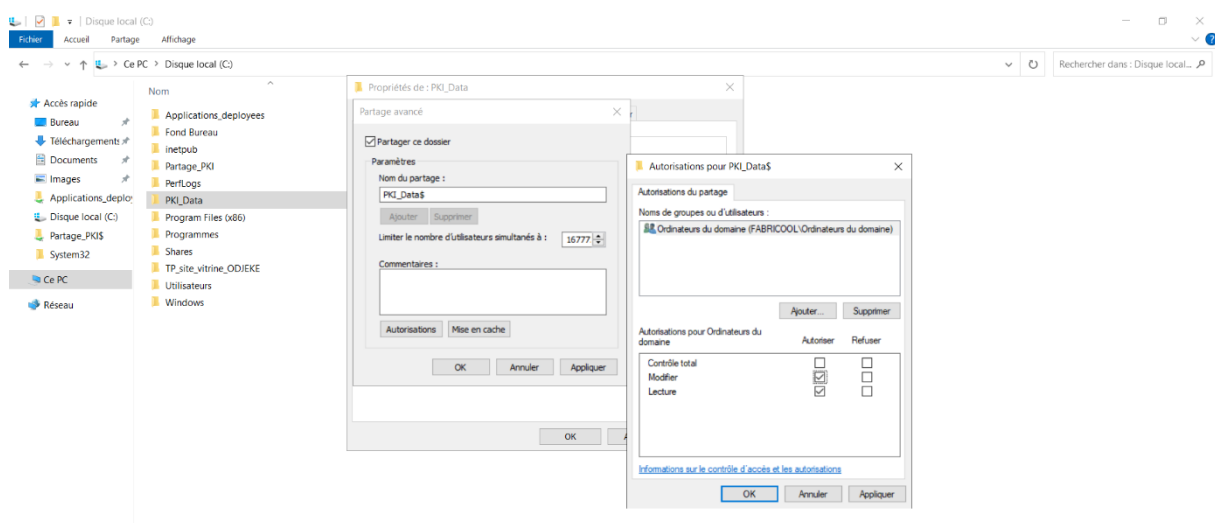


* Configuration du partage et permissions NTFS

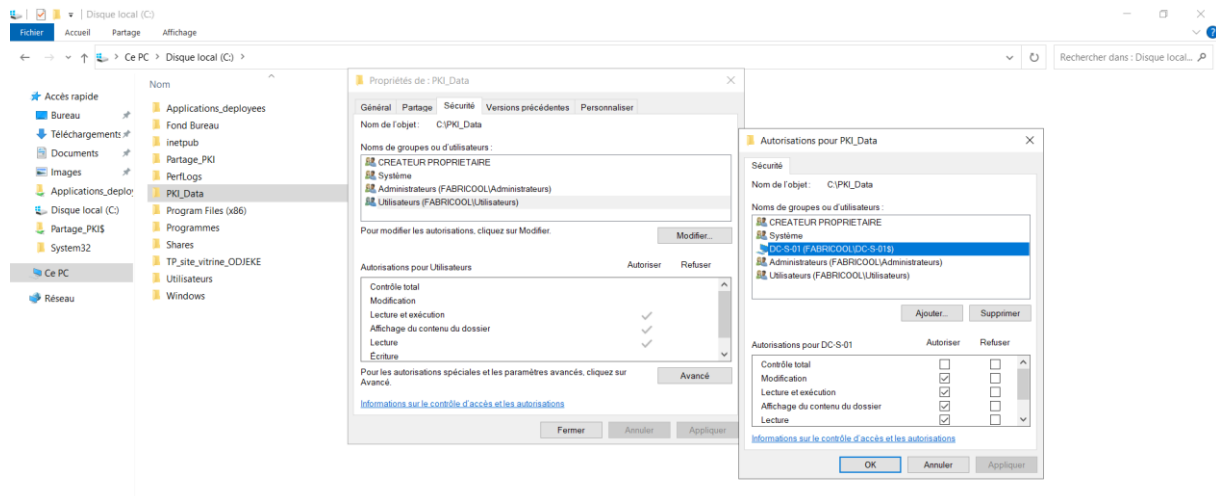
Sur le serveur DC-S-01, un dossier nommé **C:\PKI_Data** a été créé. Ce répertoire constitue l'emplacement principal où seront stockés les fichiers de certificats et de révocation destinés à être publiés. Ce répertoire a été créé spécifiquement afin d'éviter d'exposer le répertoire *CertEnroll* par défaut.

Le dossier a ensuite été partagé sous le nom **PKI_Data\$**, le symbole \$ permettant de masquer le partage dans l'explorateur réseau. Les autorisations ont été configurées de manière stricte :

- Le groupe *Ordinateurs du domaine* a reçu les droits de lecture et de modification, afin que la Subordinate CA puisse y déposer automatiquement ses fichiers.



- Au niveau NTFS, le compte machine DC-S-01 a été ajouté avec des droits d'écriture et de modification.

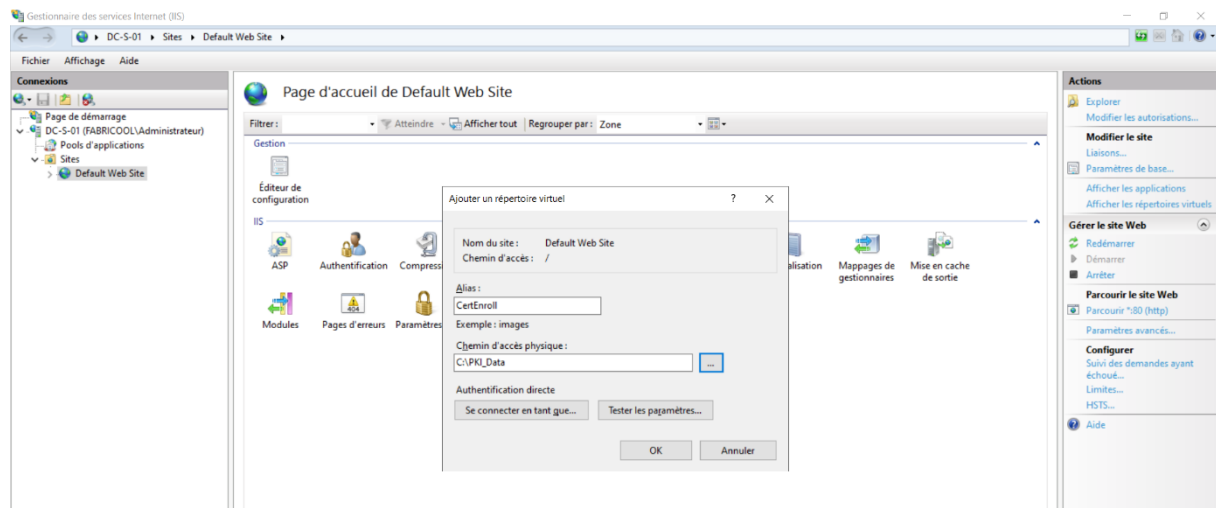


Un fichier de test, volontairement nommé *test_pki+.txt* avec un caractère spécial, a été placé dans le répertoire pour valider la future distribution.

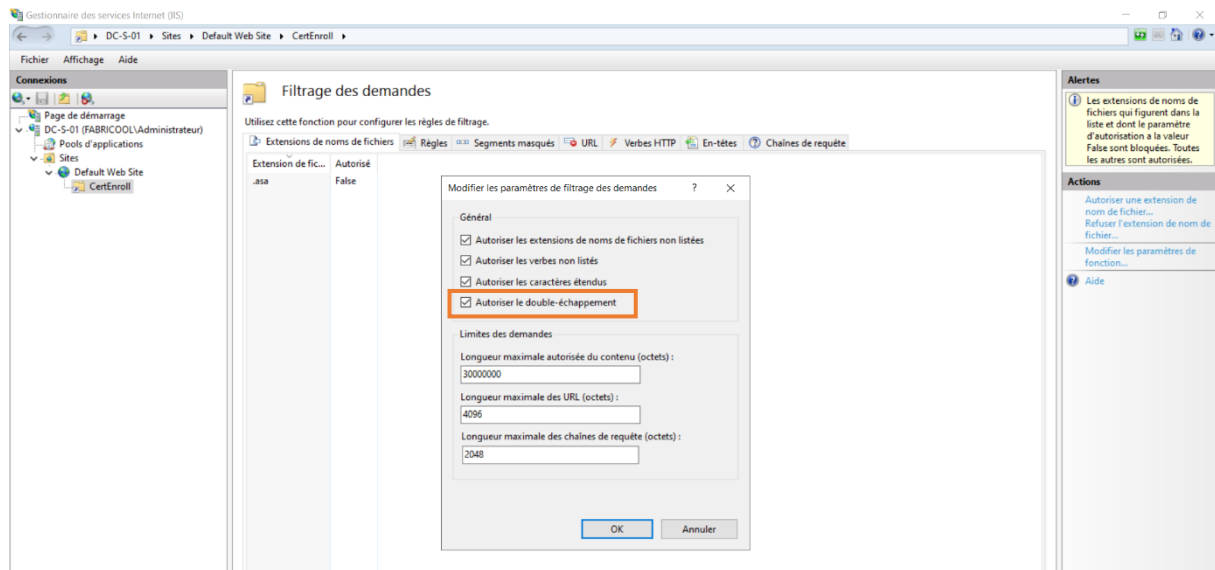
* Configuration d'IIS

La configuration du rôle IIS a permis de publier le répertoire sous un alias virtuel :

- Dans le gestionnaire des services Internet (IIS), un répertoire virtuel *CertEnroll* a été créé, pointant vers *C:\PKI_Data*.



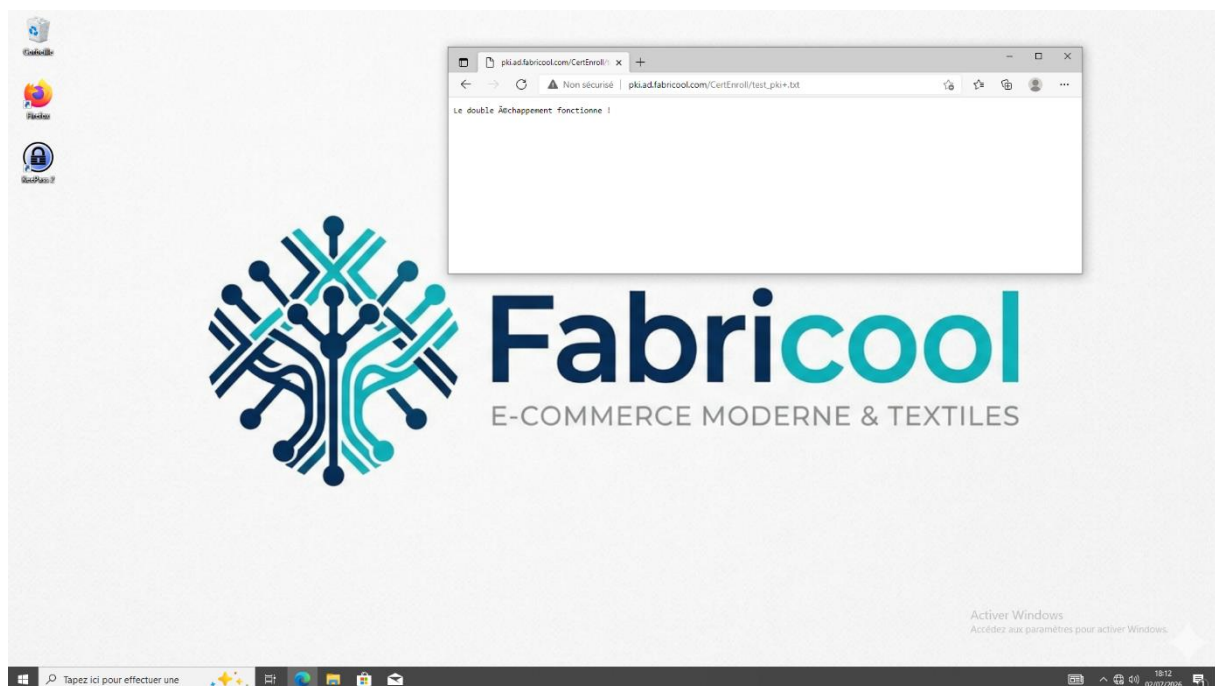
- L'exploration de répertoires a été activée afin de permettre la navigation et le téléchargement des fichiers.
- Le double échappement a été autorisé dans le *filtrage des demandes*, condition indispensable pour supporter les CRL contenant des caractères spéciaux comme le signe « + ».



Enfin, un test a été réalisé depuis un poste client en accédant à l'URL :

http://pki.ad.fabricool.com/CertEnroll/test_pki+.txt

L'affichage correct du fichier a confirmé la réussite de la configuration et la disponibilité du point de distribution HTTP.

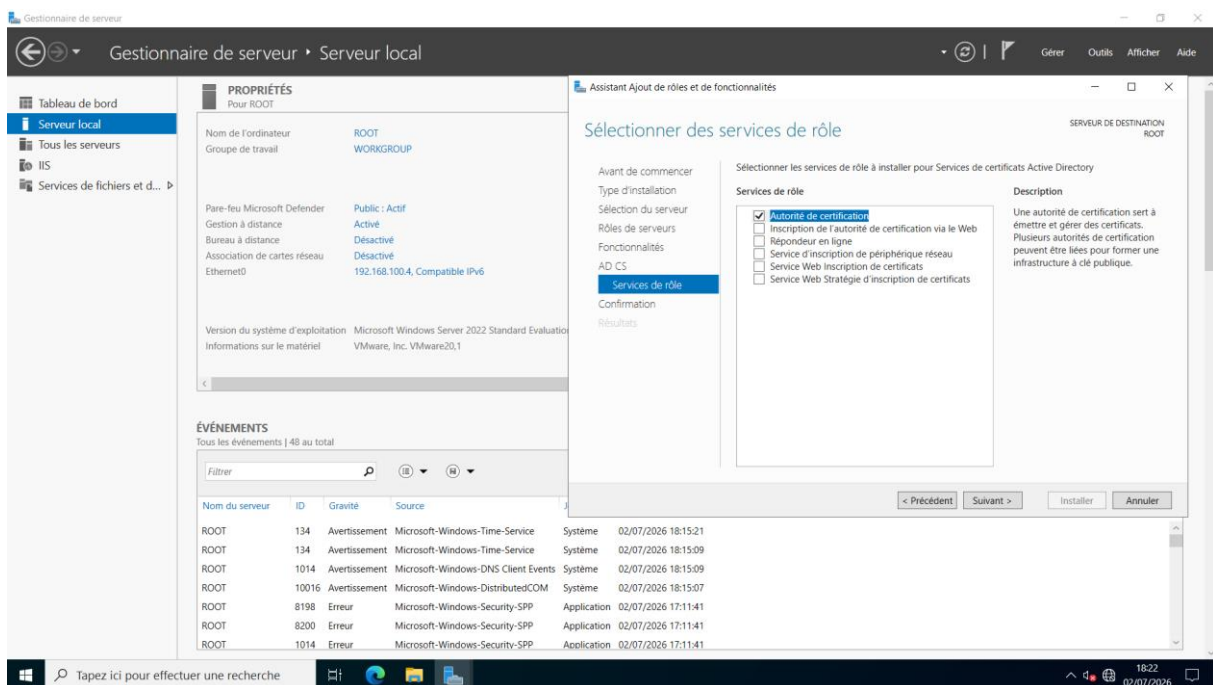


2. Déploiement de la Root CA hors-domaine (ROOT)

La mise en place de l'autorité racine constitue une étape critique dans l'architecture PKI. Cette machine, isolée du domaine et placée dans le groupe de travail *WORKGROUP*, doit rester hors ligne après le déploiement afin de protéger la clé privée principale. Les informations de configuration sont les suivantes : nom de la machine : *ROOT*, adresse IP : *192.168.100.4*.

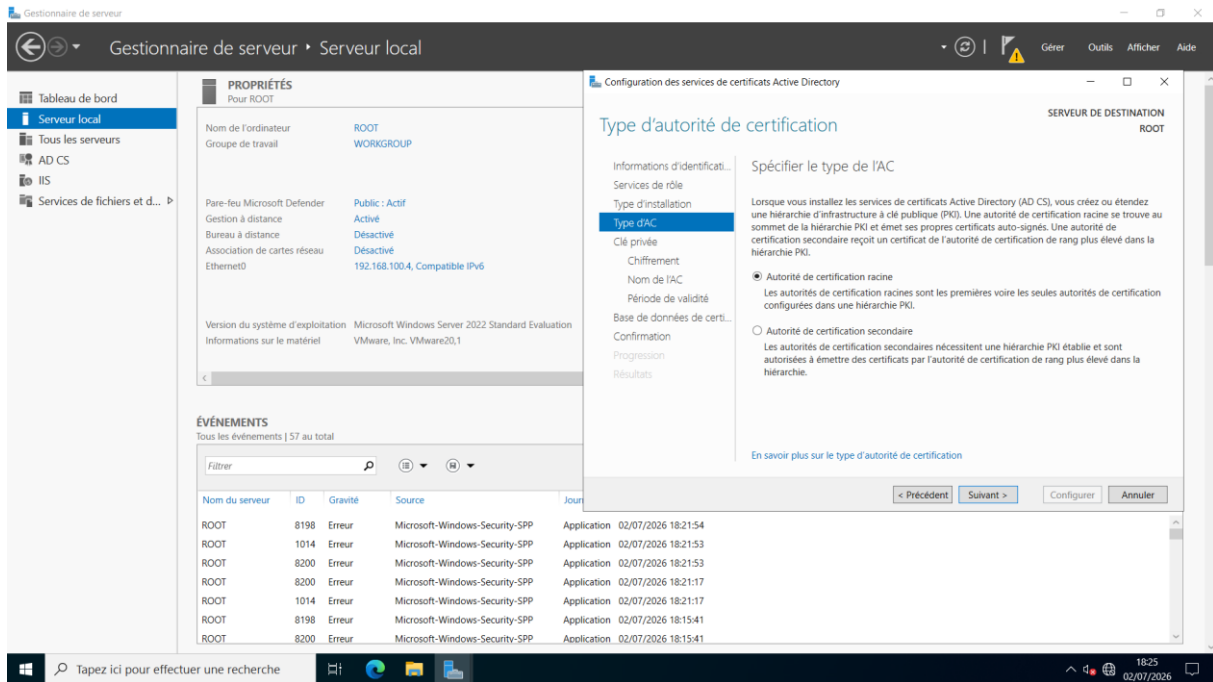
* Installation du rôle

Depuis le gestionnaire de serveur, le rôle *Services de certificats Active Directory (AD CS)* a été ajouté. Seul le service **Autorité de certification** a été sélectionné. L'installation s'est déroulée sans modification particulière des paramètres par défaut.



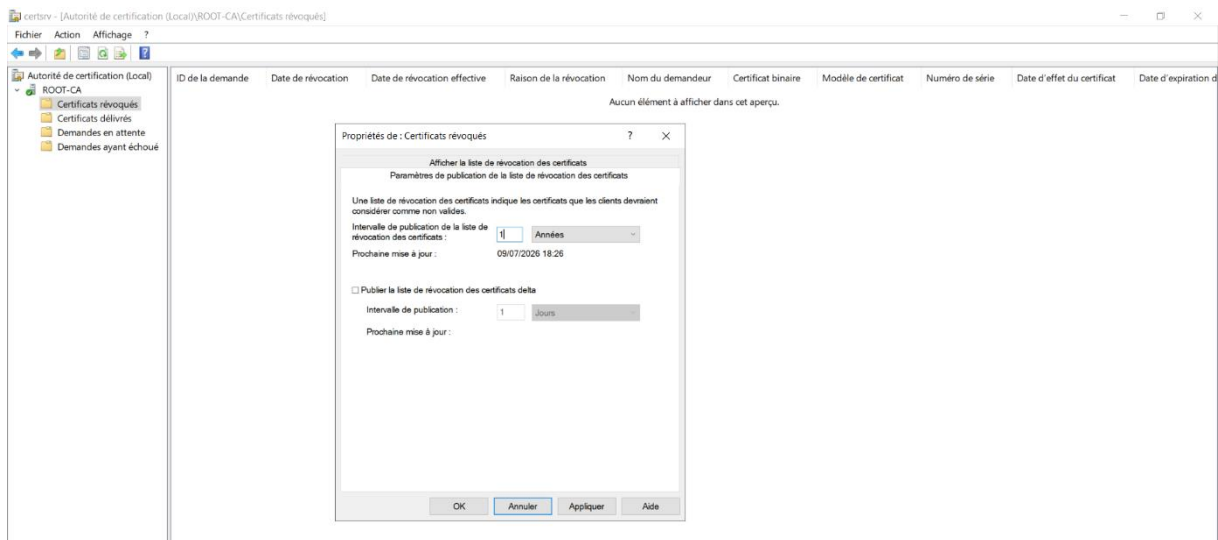
* Configuration de l'Autorité

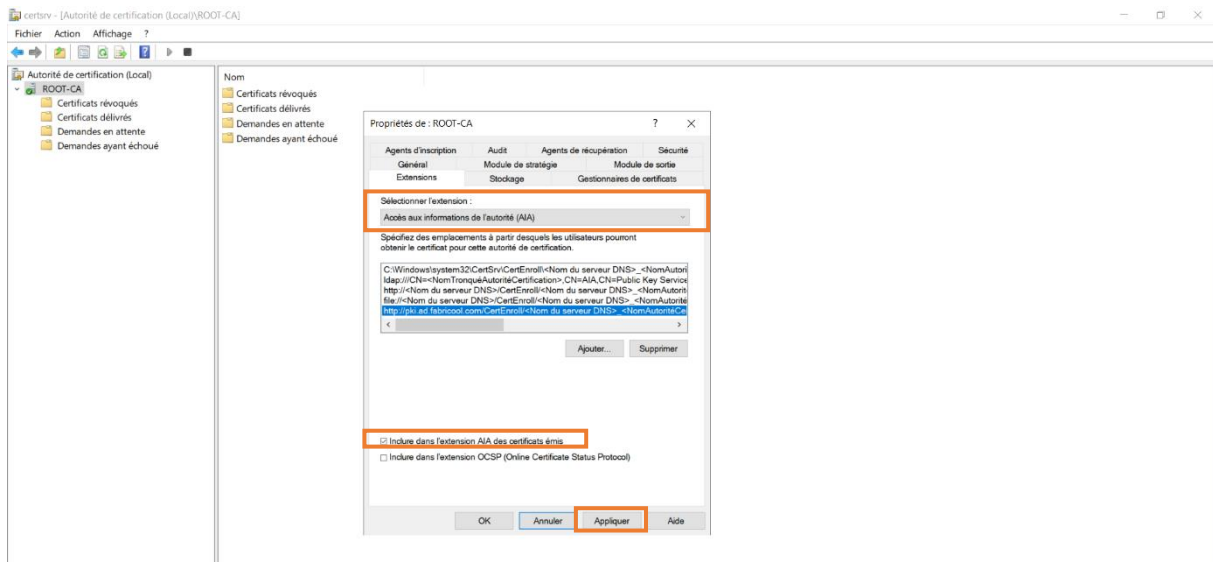
La configuration initiale a consisté à définir l'autorité comme CA autonome racine. Une nouvelle clé privée a été générée avec un chiffrement SHA256 et une taille RSA de 2048 bits (optionnellement 4096 bits pour un niveau de sécurité renforcé). Le nom commun attribué à l'autorité est *ROOT-CA*, avec une période de validité fixée à 2 ans. Les autres paramètres ont été conservés par défaut.



* Configuration des extensions et durée des CRL

Etant donné que la Root CA doit rester éteinte après le déploiement, la durée de validité de la CRL a été prolongée. Cette mesure évite de devoir rallumer la machine trop fréquemment pour republier la liste de révocation.





3. Déploiement de l'Enterprise Subordinate CA (DC-S-01)

Après la mise en place de la Root CA, l'étape suivante consiste à déployer l'autorité intermédiaire intégrée à Active Directory. Cette autorité est chargée de délivrer automatiquement les certificats aux machines et services du domaine. Le serveur concerné est DC-S-01.

* Installation du rôle

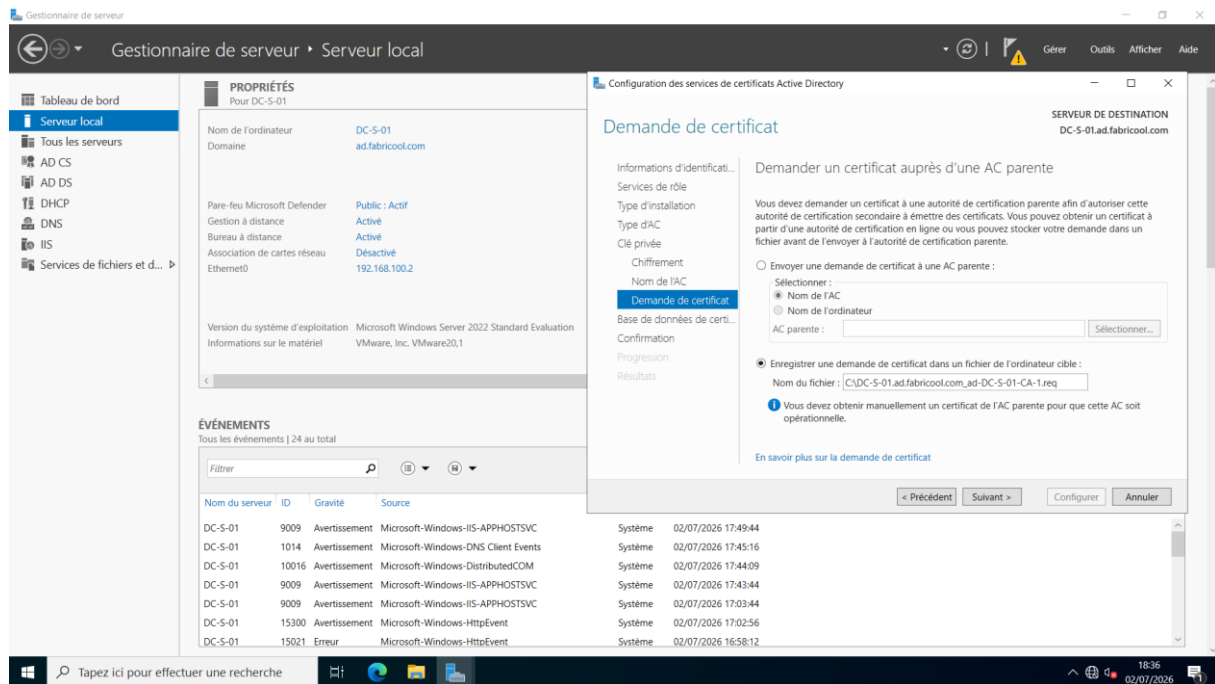
Depuis le gestionnaire de serveur, le rôle *Services de certificats Active Directory (AD CS)* a été ajouté. Seul le service **Autorité de certification** a été sélectionné. L'installation s'est déroulée avec les paramètres standards.

* Configuration de l'autorité et génération de la CSR

La configuration a ensuite permis de définir l'autorité comme CA d'entreprise intermédiaire. Les paramètres retenus sont les suivants :

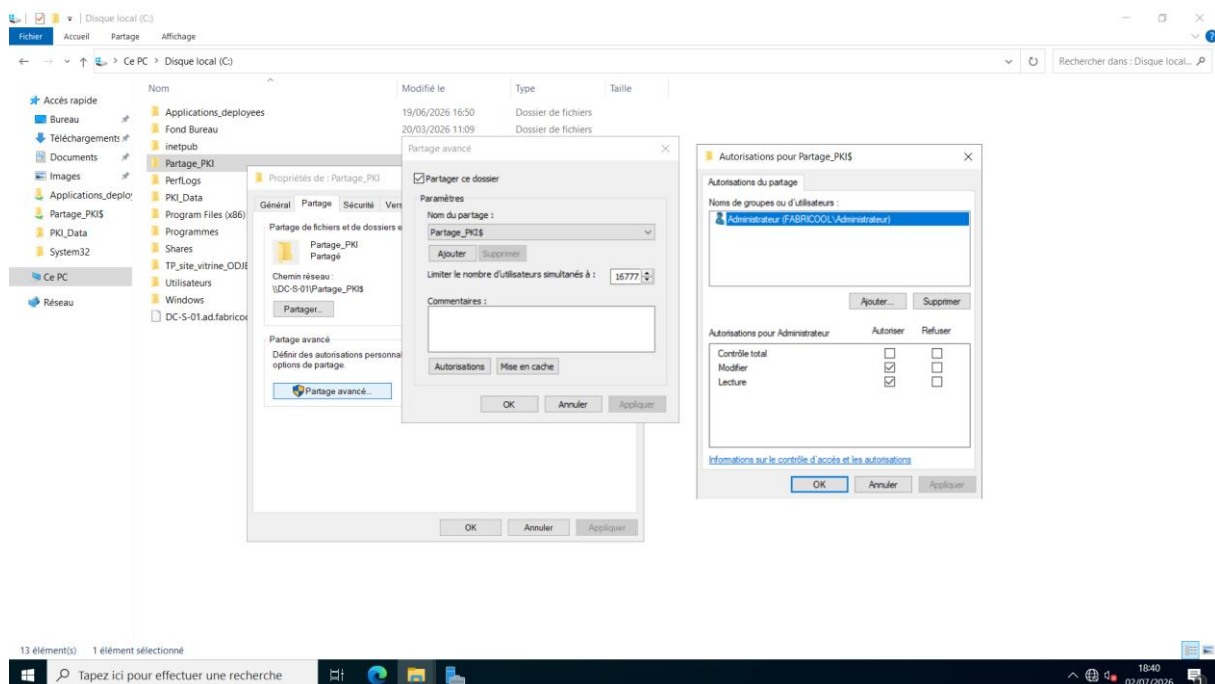
- Type d'autorité : Autorité de certification d'entreprise.
- Type de CA : Autorité de certification intermédiaire.
- Clé privée : génération d'une nouvelle clé avec chiffrement SHA256 et taille RSA de 2048 bits.
- Nom commun attribué : *ad-DC-S-01-CA*.
- La demande de certificat (CSR) a été enregistrée dans un fichier *.req* sur le serveur.

À ce stade, le service AD CS n'a pas démarré, ce comportement étant normal tant que la demande n'a pas été signée par la Root CA.



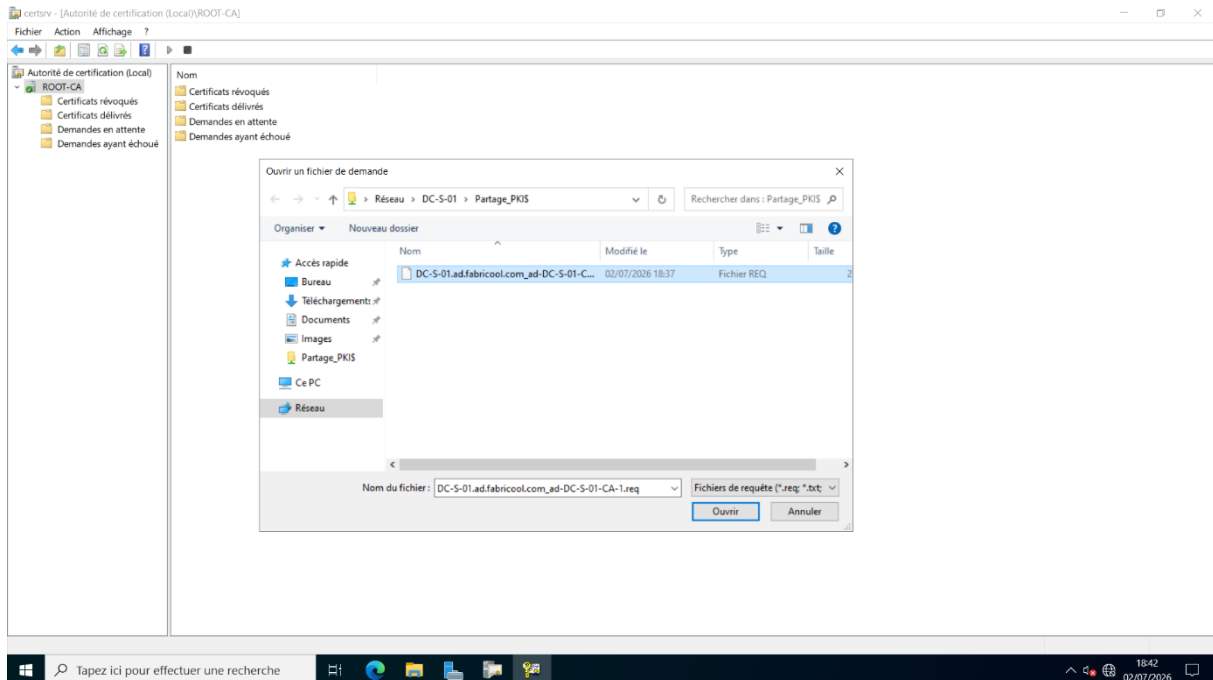
4. Signature de la CSR par la Root CA

La CSR générée sur DC-S-01 a été transférée vers la Root CA en **mode déconnecté**. Pour faciliter ce transfert, un dossier partagé masqué nommé *Partage_PKI\$* a été créé. Les droits de modification ont été attribués uniquement au compte Administrateur, garantissant que seuls les administrateurs des deux machines puissent y accéder. Ce partage avait un caractère temporaire et a été supprimé une fois les opérations terminées.



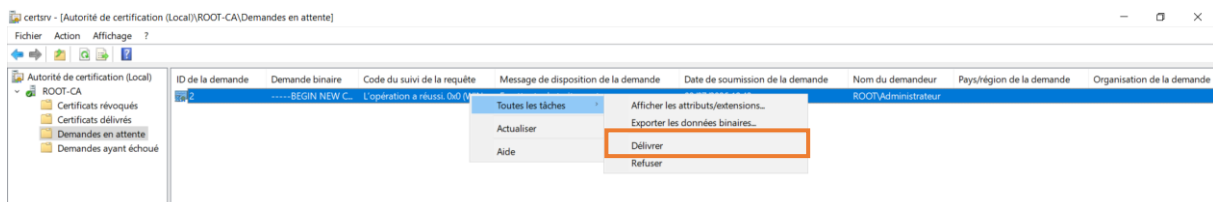
* Soumission de la requête

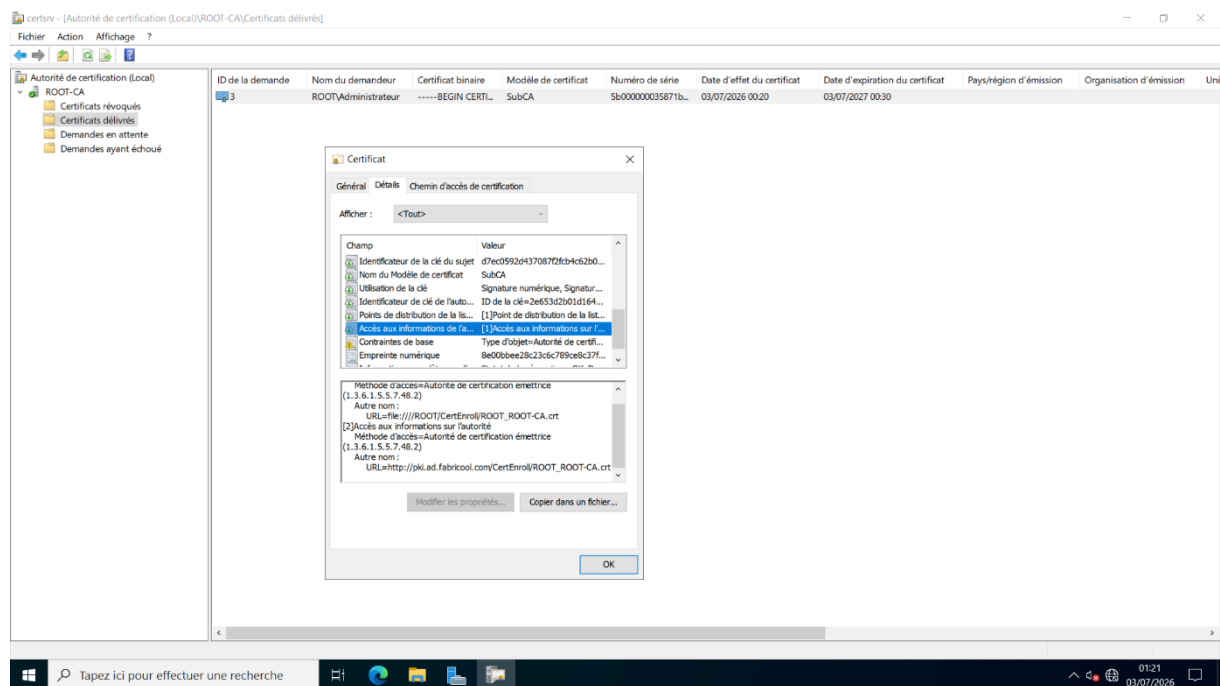
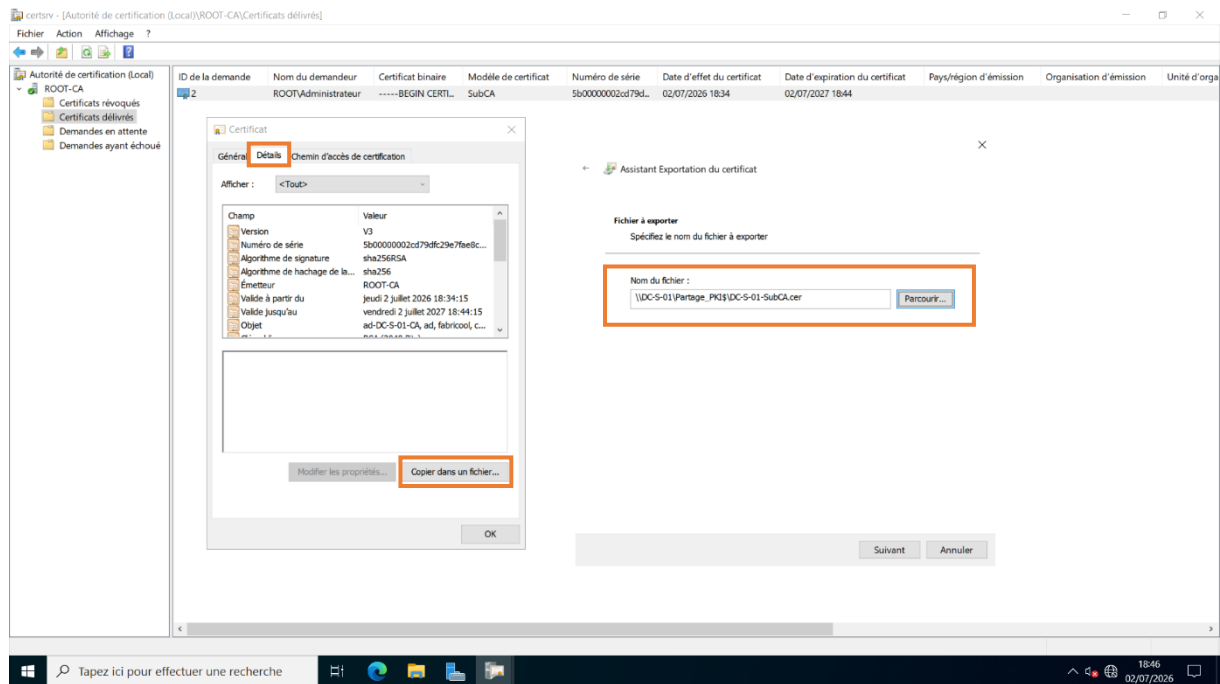
Le fichier *.req* a été copié dans le partage temporaire *Partage_PKI\$*. Depuis la console *Autorité de certification* (certsrv.msc) sur le serveur ROOT, la requête a été soumise via le menu : *Toutes les tâches > Soumettre une nouvelle requête*.



* Approbation et export du certificat

La requête a été approuvée, ce qui a généré le certificat subordonné. Celui-ci a été exporté au format *.cer* et placé dans le partage afin d'être récupéré par DC-S-01. Une vérification des informations contenues dans le certificat délivré a permis de confirmer la présence correcte des extensions CDP et AIA.





* Publication de la CRL

Afin de compléter la chaîne de confiance, une nouvelle CRL a été publiée depuis la console de la Root CA. Faites un clic droit sur *Certificats révoqués* > *Toutes les tâches* > *Publier*. Sélectionner *Nouvelle CRL*. Le fichier obtenu, ainsi que le certificat racine (.crt), ont été récupérés dans le répertoire *C:\Windows\System32\CertSrv\CertEnroll*. Ces fichiers ont ensuite été transférés dans le partage temporaire.

* Renommage et transfert final

Les fichiers exportés ont été renommés afin de correspondre exactement aux chemins attendus par les extensions CDP et AIA. Cette étape est cruciale : elle garantit que les certificats délivrés par la Subordinate CA pointeront vers des URL valides et cohérentes. Les fichiers ont ensuite été copiés sur DC-S-01 dans le dossier **C:\PKI_Data**, assurant ainsi leur disponibilité via le point de distribution HTTP.

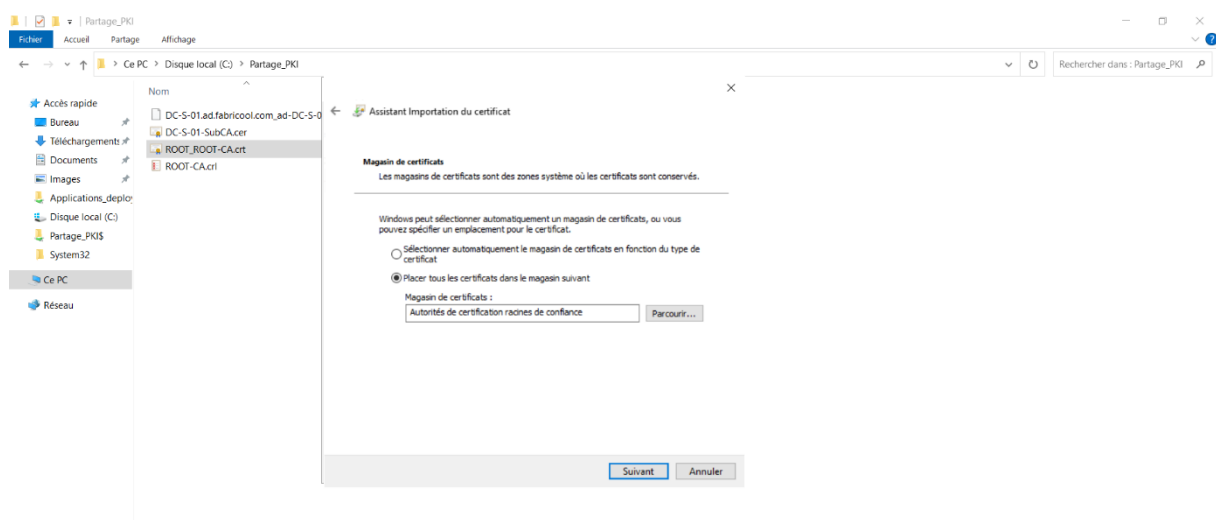
NB : Il est important de noter que les fichiers exportés au format .cer et .crt sont équivalents du point de vue du traitement par les systèmes : ils représentent tous deux des certificats X.509 et peuvent être utilisés indifféremment selon le contexte. Par ailleurs, les numéros et noms attribués aux fichiers de requêtes .csr peuvent varier selon les captures d'écran, car plusieurs tests ont été réalisés avant la configuration définitive. Il convient donc de ne pas tenir compte de ces variations et de suivre uniquement la logique des étapes décrites, en veillant à respecter la cohérence entre la génération de la CSR, sa signature par la Root CA et l'intégration des certificats et CRL dans le point de distribution HTTP.

5. Finalisation et configuration des extensions sur DC-S-01

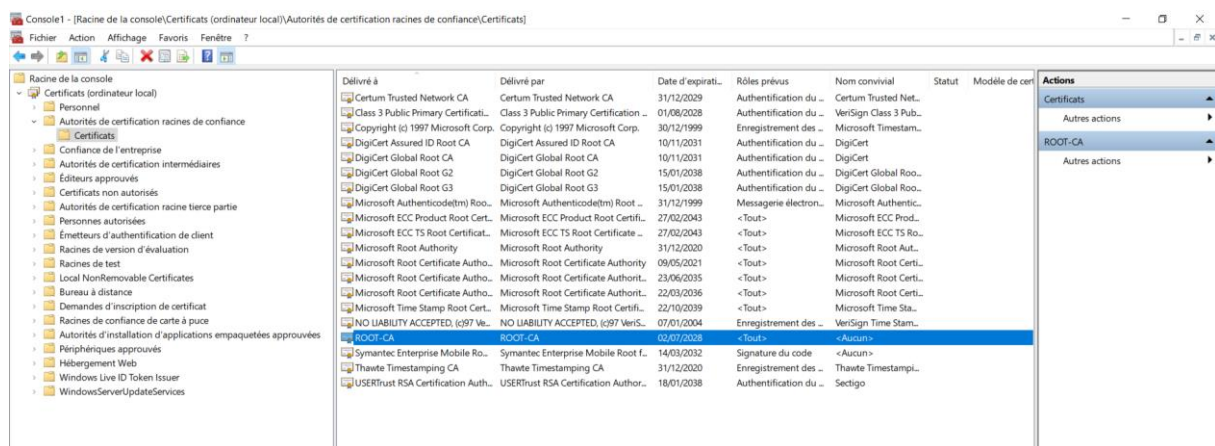
Avant d'installer le certificat délivré par la Root CA, il a été nécessaire de préparer le serveur DC-S-01 pour qu'il reconnaisse l'autorité racine et puisse valider correctement la chaîne de certification.

* Installation du certificat racine et ajout de la CRL

Le certificat de la ROOT-CA a été installé par interface graphique dans le magasin des *Autorités de certification racines de confiance* de DC-S-01.



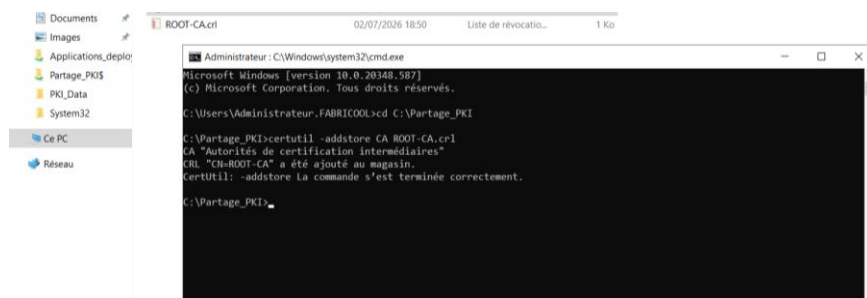
Une vérification a ensuite été effectuée via le snap-in afin de confirmer sa présence.



En complément, la liste de révocation de la Root CA a été ajoutée par ligne de commande :

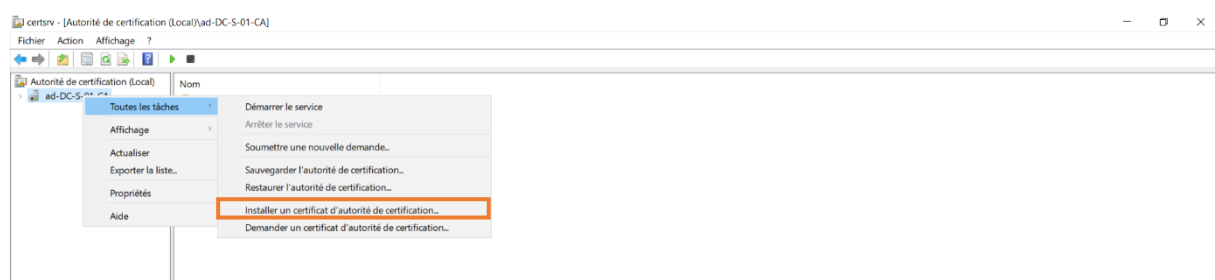
certutil -addstore CA ROOT-CA.crl

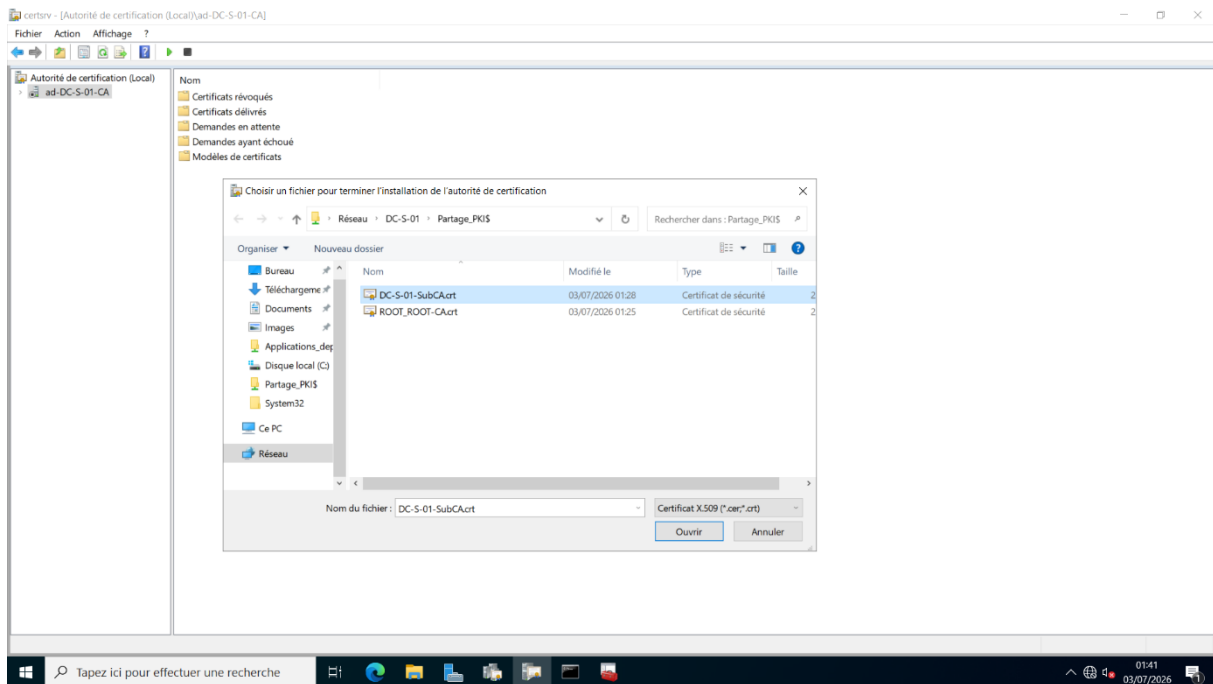
Cette opération a été réalisée depuis le répertoire du partage temporaire, garantissant que la Sub CA dispose des informations nécessaires pour vérifier l'état des certificats émis par la Root.



* Installation du certificat de la CA intermédiaire

Une fois le certificat racine installé, le certificat délivré par la Root CA pour la CA intermédiaire a été importé via la console certsrv.msc. Après sélection du fichier .cer, le service AD CS a pu être démarré sur DC-S-01. Le certificat de l'autorité intermédiaire a ensuite été copié depuis le répertoire *CertEnroll*, puis placé dans le dossier *PKI_Data* afin d'être publié par IIS.





* Configuration des extensions HTTP (CDP & AIA)

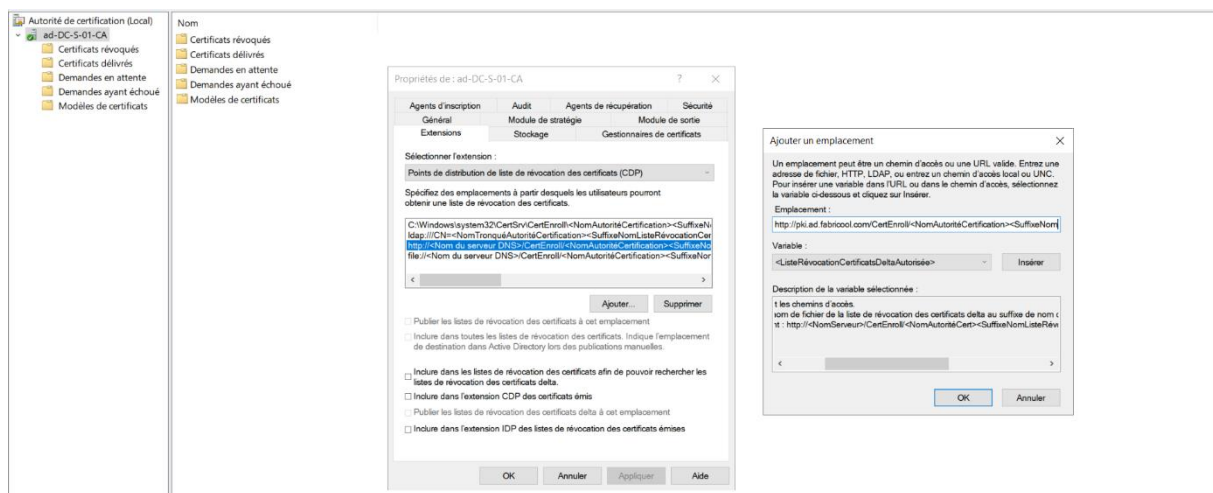
La configuration des extensions a été ajustée pour supprimer toute référence LDAP ou File par défaut et ne conserver que les chemins HTTP et locaux nécessaires :

o Extension CDP (Point de distribution de la CRL)

http://pki.ad.fabricool.com/CertEnroll/<CaName><CRLNameSuffix><DeltaCRLAllowed>.crl

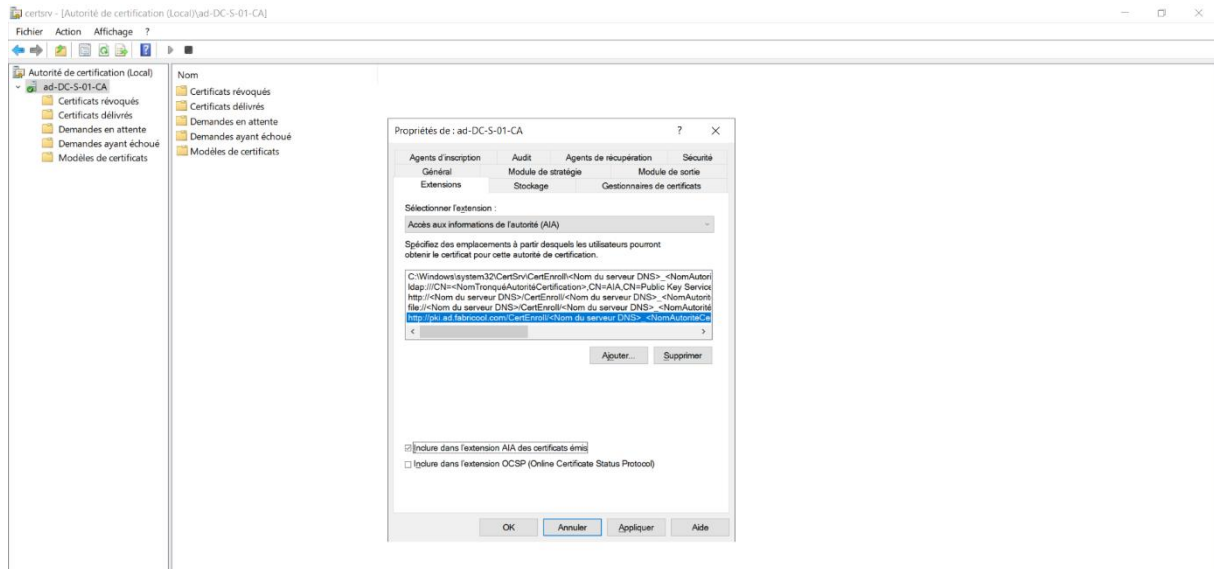
Les options Inclure dans les CRL et Inclure dans l'extension CDP des certificats délivrés ont été cochées. En complément, un chemin local a été défini :

C:\PKI_Data\<CaName><CRLNameSuffix><DeltaCRLAllowed>.crl permettant à la CA intermédiaire de publier directement ses CRL dans le répertoire IIS. Les options de publication uniquement ont été cochées pour ce chemin.



- **Extension AIA (Accès aux informations sur l'autorité) :**

`http://pki.ad.fabricool.com/CertEnroll/<ServerDNSName>_<CaName><CertificateName>.crt`
avec l'option *Inclure dans l'extension AIA des certificats délivrés*.



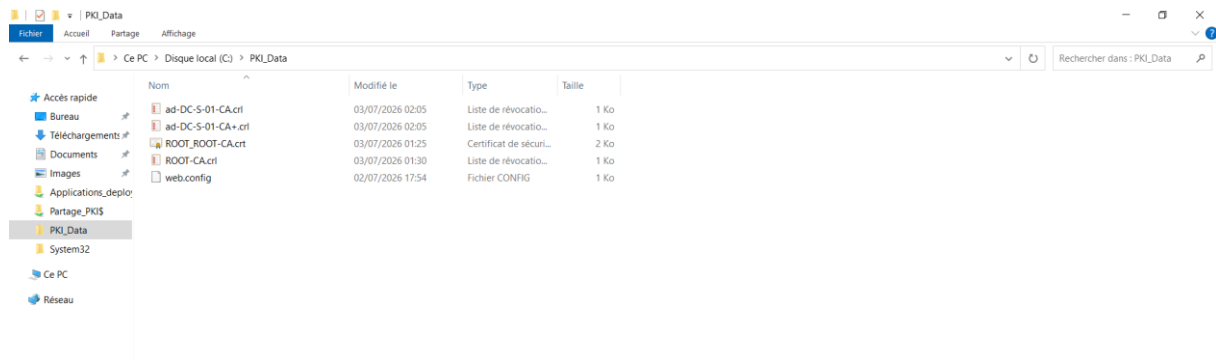
Après validation, le service AD CS a été redémarré pour appliquer les changements. Cette configuration stricte assure que la chaîne de certification repose uniquement sur le point de distribution HTTP centralisé, conformément aux objectifs de sécurité définis pour l'infrastructure PKI.

6. Publication et Validation Finale

La dernière étape du déploiement consiste à publier la liste de révocation de la CA intermédiaire et à valider l'ensemble de la chaîne de certification via l'outil de diagnostic intégré.

- * **Publication de la CRL**

Depuis la console `certsrv.msc` sur DC-S-01, une nouvelle CRL a été générée en sélectionnant *Certificats révoqués > Toutes les tâches > Publier > Nouvelle CRL*. Cette opération a permis de créer automatiquement les fichiers de révocation de la CA intermédiaire dans le répertoire `C:\PKI_Data`, confirmant que la configuration des extensions locales était correcte.

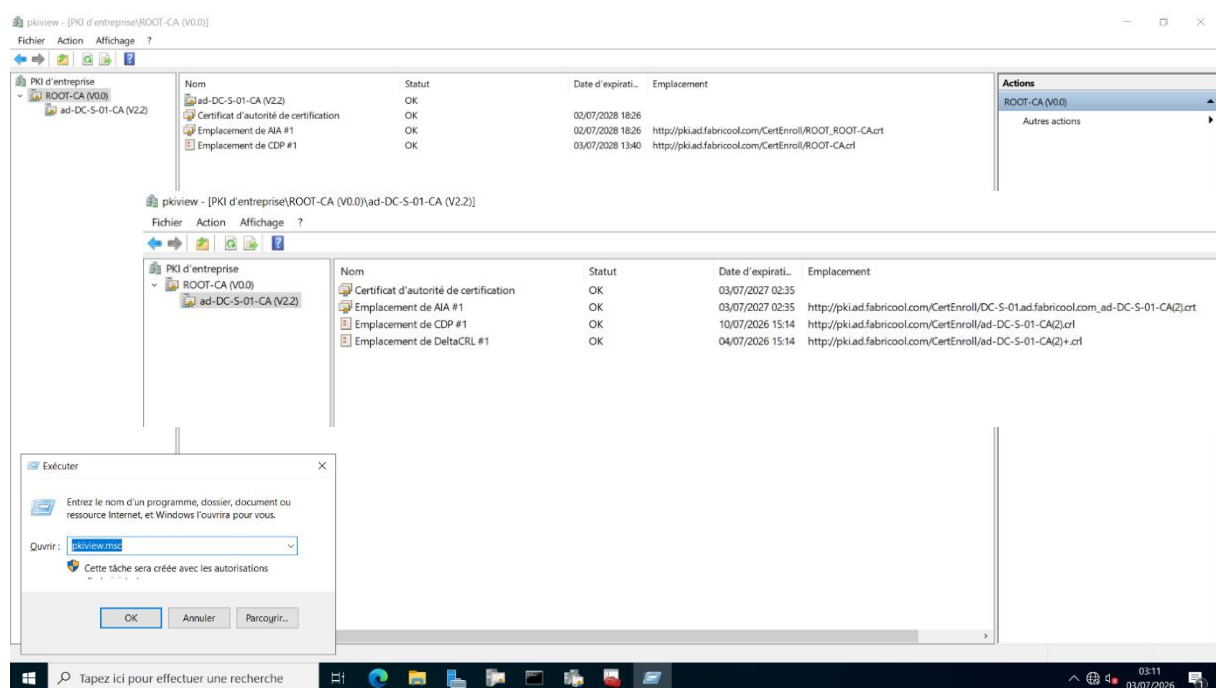


Sur cette capture, on remarque que les fichiers de révocation (**CRL**) ont bien été publiés dans le répertoire **PKI_Data**, tandis que le certificat de l'autorité intermédiaire est absent. Celui-ci a été copié par la suite depuis le répertoire **CertEnroll**, ce qui illustre l'une des erreurs rencontrées au cours de ce TP et qui m'a permis de progresser en consolidant ma compréhension du processus.

* Validation via PKIView

Enfin, l'outil **pkiview.msc** a été exécuté depuis une invite de commande. Le diagnostic a confirmé que tous les voyants, tant pour la Root CA que pour la CA intermédiaire, étaient passés au statut OK pour l'accès HTTP.

En cas d'erreur sur un voyant AIA ou CDP de la Root CA, la vérification doit porter sur le nommage et le dépôt manuel des fichiers racine (.crt et .crl) dans le répertoire **C:\PKI_Data**. Ces fichiers doivent correspondre exactement aux chemins attendus par les extensions configurées dans les certificats délivrés.



V. Conclusion

Le déploiement de l'infrastructure PKI hiérarchique au sein de l'entreprise FABRICOOL a permis de mettre en place une chaîne de certification robuste et conforme aux bonnes pratiques de sécurité. L'isolement de la Root CA hors domaine, associé à la configuration stricte des extensions CDP et AIA en mode HTTP, garantit la protection de la clé privée principale tout en assurant une distribution fiable des certificats et des listes de révocation.

La CA intermédiaire intégrée à Active Directory assure désormais la délivrance automatisée des certificats pour les machines et services du domaine, tandis que le serveur IIS centralise la publication des fichiers nécessaires à la validation de la confiance. Les tests réalisés via *pkiview.msc* ont confirmé la cohérence de l'architecture : tous les voyants sont passés au statut OK, validant ainsi la disponibilité des points de distribution et l'intégrité de la chaîne de certification.

Ce TP a également permis de mettre en évidence certaines erreurs de configuration initiales, notamment l'absence temporaire du certificat de l'autorité intermédiaire dans le répertoire de publication. Ces ajustements ont constitué des étapes d'apprentissage essentielles, renforçant la compréhension des mécanismes de confiance et la rigueur nécessaire à la mise en œuvre d'une PKI en environnement professionnel.

En définitive, l'infrastructure déployée constitue un socle fiable pour la sécurisation des communications internes et des services de l'entreprise, tout en offrant une base évolutive pour de futurs déploiements orientés vers la haute disponibilité et l'interopérabilité multiplateformes.